

UD3 - Criptografía

Fundamentos, cifrado, integridad, firma digital y certificados para proteger la información y las comunicaciones.

Datos de la unidad	Información
Módulo	Seguridad y Alta Disponibilidad
Curso	2.º ASIR
Modalidad	Semipresencial
Duración	14 horas

Índice

1. [Fundamentos y propiedades de seguridad](#)
2. [Criptografía simétrica](#)
3. [Criptografía asimétrica](#)
4. [Funciones hash, firmas y protección de contraseñas](#)
5. [Certificados, PKI y TLS](#)
6. [Resumen](#)
7. [Recursos](#)
8. [Relación con los resultados de aprendizaje](#)

1. Fundamentos y propiedades de seguridad

1.1. Introducción

La criptografía constituye una de las principales herramientas para proteger la información y las comunicaciones de los sistemas informáticos.

En esta unidad se estudiarán los fundamentos de la criptografía y los principales mecanismos utilizados actualmente para proteger la información: cifrado simétrico, cifrado asimétrico, funciones hash, firmas digitales y certificados digitales.

Se prestará especial atención a la selección del mecanismo adecuado según el objetivo de seguridad y al uso responsable de claves, certificados y algoritmos normalizados.

El objetivo es que el alumnado no solo conozca los algoritmos criptográficos, sino que sea capaz de identificar qué mecanismo debe utilizar en cada situación y por qué.

1.2. Objetivos

Al finalizar la unidad, el alumnado será capaz de:

- Comprender los fundamentos de la criptografía.
- Identificar las propiedades de seguridad que proporciona.

- Diferenciar cifrado, hash y firma digital.
- Comprender el funcionamiento de la criptografía simétrica.
- Conocer los principales algoritmos simétricos.
- Comprender el funcionamiento de la criptografía asimétrica.
- Diferenciar clave pública y clave privada.
- Conocer algoritmos como RSA y ECC.
- Comprender el funcionamiento de las funciones hash.
- Conocer los mecanismos utilizados para proteger contraseñas.
- Comprender el concepto de firma digital.
- Comprender el funcionamiento de los certificados digitales.
- Conocer el concepto de PKI.
- Comprender el papel de las autoridades certificadoras.
- Comprender el funcionamiento básico de HTTPS/TLS.
- Aplicar buenas prácticas en la gestión de claves.

1.3. ¿Qué es la criptografía?

La criptografía engloba técnicas matemáticas utilizadas para proteger información.

Permite implementar mecanismos relacionados con:

Confidencialidad. Integridad. Autenticidad. No repudio.

En un sistema criptográfico podemos encontrar:

Información original: datos que queremos proteger. Algoritmo criptográfico: procedimiento utilizado. Clave: información que controla el proceso criptográfico. Texto cifrado: resultado del cifrado. Descifrado: proceso para recuperar la información original.

Ejemplo:

CLAVE
|
▼

Texto claro → CIFRADO → Texto cifrado | ▼ DESCIFRADO | ▼ Texto claro

1.4. Propiedades de seguridad

1.4.1. Confidencialidad

La información solo debe poder ser consultada por usuarios autorizados.

Ejemplo:

Una empresa almacena las nóminas de sus trabajadores en un servidor. Si los archivos están cifrados, obtener físicamente una copia de ellos no debería permitir leer su contenido sin disponer de la clave adecuada.

1.4.2. Integridad

Permite detectar modificaciones realizadas sobre la información.

Por ejemplo, podemos calcular un hash de un fichero:

Fichero | ▼ SHA-256 | ▼ Hash

Si el fichero cambia, el hash resultante también debería cambiar.

1.4.3. Autenticidad

Permite comprobar la identidad del origen de una información.

Por ejemplo, una firma digital permite comprobar que un documento ha sido firmado mediante una determinada clave privada.

1.4.4. No repudio

Permite disponer de mecanismos que relacionen una determinada acción con su autor.

Las firmas digitales pueden contribuir al no repudio, aunque su validez también depende del contexto legal y de los procedimientos utilizados.

1.5. Principio de Kerckhoffs

La seguridad de un sistema criptográfico no debe depender de mantener secreto el algoritmo, sino de proteger correctamente la clave. Este principio permite que algoritmos como AES, RSA o las funciones SHA sean públicos, revisados por especialistas y utilizados por muchas organizaciones. Ocultar el funcionamiento de un algoritmo no es una medida suficiente: si se descubre, el sistema no debería quedar expuesto.

En la práctica, una organización debe seleccionar algoritmos normalizados, aplicar implementaciones mantenidas y centrar sus controles en la generación, almacenamiento, rotación y revocación de las claves. Por ejemplo, usar AES correctamente con una clave protegida resulta preferible a utilizar un algoritmo propio cuyo funcionamiento nadie ha revisado.

1.6. Aplicaciones de la criptografía

La criptografía se aplica a datos en tránsito y en reposo. HTTPS protege la comunicación entre un navegador y un servidor; el cifrado de disco reduce el impacto del robo de un portátil; PGP y S/MIME pueden proteger el correo electrónico; y las firmas digitales permiten comprobar la integridad y autoría de documentos o programas. Tecnologías como blockchain también utilizan hashes y firmas para verificar transacciones, aunque una cadena de bloques no sustituye los controles de seguridad convencionales.

La elección depende del objetivo. Para ocultar una copia de seguridad se utiliza cifrado; para comprobar que una descarga no se ha alterado se utiliza un hash; para demostrar el origen de un documento se emplea una firma digital; y para confiar en la identidad de un servidor web se utiliza un certificado dentro de una PKI.

En el correo electrónico, PGP suele basarse en una red de confianza entre usuarios, mientras que S/MIME utiliza habitualmente certificados emitidos por una autoridad de certificación. En almacenamiento, herramientas como BitLocker, FileVault o LUKS cifran los datos en reposo; el cifrado de un proveedor en la nube no elimina la necesidad de controlar accesos, copias, claves y configuración. En blockchain, las claves

privadas autorizan operaciones y los hashes enlazan los bloques, pero la pérdida de una clave privada puede impedir el acceso a los activos asociados.

2. Criptografía simétrica

2.1. Cifrado

El cifrado transforma información legible en información que no debería poder interpretarse sin disponer de la clave correspondiente.

INFORMACIÓN ORIGINAL | | Cifrado ▼ INFORMACIÓN CIFRADA | | Descifrado ▼ INFORMACIÓN ORIGINAL

Un sistema criptográfico moderno debe utilizar algoritmos y claves suficientemente robustos.

La seguridad no debería depender de que el algoritmo sea secreto.

2.2. Criptografía simétrica

La criptografía simétrica utiliza una misma clave secreta para cifrar y descifrar.

CLAVE
|
▼

Mensaje —————> CIFRADO | ▼ Mensaje cifrado | ▼ DESCIFRADO | ▼ Mensaje

El principal problema es cómo conseguir que emisor y receptor compartan la clave de forma segura.

2.3. Ventajas e inconvenientes de la criptografía simétrica

Ventajas Es rápida. Consume pocos recursos. Es adecuada para grandes cantidades de información. Se utiliza habitualmente para cifrar datos y comunicaciones. Inconveniente

El intercambio inicial de la clave puede ser un problema.

Si un atacante consigue la clave secreta, podrá utilizarla para descifrar la información protegida con ella.

2.4. Algoritmos simétricos

Algunos algoritmos conocidos son:

AES. ChaCha20. 3DES. DES.

Actualmente:

AES es un estándar ampliamente utilizado. ChaCha20 también se utiliza en sistemas modernos. DES se considera obsoleto. 3DES está obsoleto para nuevos diseños.

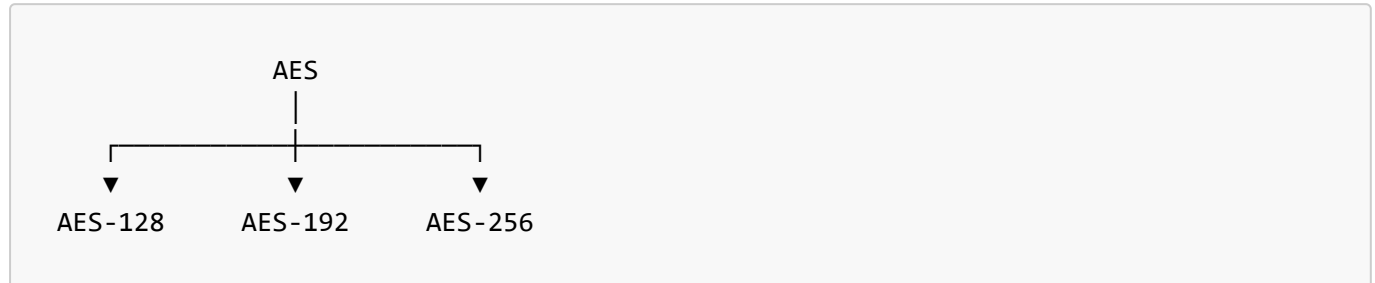
2.5. AES

AES (Advanced Encryption Standard) es uno de los algoritmos de cifrado simétrico más utilizados.

Admite claves de:

128 bits. 192 bits. 256 bits.

Por ejemplo:



AES se utiliza en numerosos sistemas de almacenamiento, comunicaciones y aplicaciones.

2.6. Modos de operación y cifrado autenticado

AES es un cifrador de bloques y necesita un modo de operación para proteger mensajes de tamaño variable. El modo **ECB** no debe utilizarse para información sensible porque bloques iguales producen resultados iguales y pueden revelar patrones. Los modos modernos de cifrado autenticado, como **AES-GCM** o **ChaCha20-Poly1305**, protegen la confidencialidad y además detectan cambios no autorizados mediante una etiqueta de autenticación.

El vector de inicialización o *nonce* no suele ser secreto, pero debe cumplir las condiciones del modo elegido; en especial, no debe reutilizarse con la misma clave cuando el algoritmo lo prohíbe. Una elección segura no consiste solo en escoger AES-256: también requiere un modo adecuado, una biblioteca actualizada y una gestión correcta de claves y *nonces*.

3. Criptografía asimétrica

3.1. Criptografía asimétrica

La criptografía asimétrica utiliza un par de claves:

Clave pública. Clave privada.

Las dos claves están relacionadas matemáticamente.

PAR DE CLAVES

| | ▼ ▼ Clave pública Clave privada | | Puede distribuirse Debe protegerse

La clave privada nunca debería compartirse.

3.2. Clave pública

La clave pública puede distribuirse a otras personas o sistemas.

Puede utilizarse, según el algoritmo y el protocolo, para:

Cifrar información destinada al propietario. Verificar firmas. Participar en mecanismos de establecimiento de claves.

3.3. Clave privada

La clave privada debe mantenerse protegida.

Puede utilizarse para:

Descifrar información. Generar firmas digitales. Autenticarse mediante certificados. Participar en determinados protocolos criptográficos.

Una clave privada comprometida puede poner en riesgo todo el sistema que dependa de ella.

3.4. RSA

RSA es uno de los algoritmos asimétricos más conocidos.

Puede utilizarse para:

Cifrado. Firmas digitales. Determinados mecanismos de intercambio o establecimiento de claves.

Una de sus características es que trabaja con un par de claves:

Clave pública | ▼ RSA ▲ | Clave privada

3.5. Criptografía de curva elíptica

La criptografía basada en curvas elípticas, conocida como ECC, permite implementar sistemas criptográficos de clave pública utilizando tamaños de clave menores que RSA para niveles de seguridad comparables en determinados escenarios.

Algunos sistemas relacionados son:

ECDSA. ECDH. EdDSA.

Se utilizan ampliamente en tecnologías modernas.

3.6. Simétrica frente a asimétrica

Característica	Simétrica	Asimétrica	Claves	Una clave secreta	Pública + privada	Velocidad	Alta	Menor	Grandes
cantidades de datos	Muy adecuada	Menos adecuada	Gestión de claves	Más complicada	Facilita el intercambio	Firmas digitales	No es su objetivo principal	Sí	Ejemplos AES, ChaCha20 RSA, ECC

En sistemas reales es habitual utilizar las dos tecnologías conjuntamente.

Por ejemplo:

Criptografía asimétrica | ▼ Intercambio/protección de clave | ▼ Criptografía simétrica | ▼ Transmisión de datos

Los protocolos actuales combinan ambos enfoques: la criptografía de clave pública autentica a las partes y permite establecer secretos de sesión; después, un algoritmo simétrico cifra la mayor parte de los datos por su mejor rendimiento. TLS es un ejemplo habitual de esta combinación.

3.7. Diffie-Hellman y gestión de claves

Diffie-Hellman permite que dos partes establezcan un secreto compartido a través de una red no confiable sin enviar ese secreto directamente. Sus variantes modernas, como ECDH, se utilizan para crear claves de sesión. Por sí solo no autentica a las partes, por lo que debe combinarse con certificados, firmas u otro mecanismo de autenticación para evitar ataques de intermediario.

Las claves privadas deben almacenarse con permisos restrictivos, cifrado y copias de seguridad protegidas. Una organización debe documentar quién puede utilizarlas, separarlas por entorno, rotarlas cuando corresponda y revocarlas ante una sospecha de exposición. En sistemas de riesgo elevado pueden emplearse HSM, tarjetas inteligentes o tokens, que realizan la operación criptográfica sin exponer la clave privada.

4. Funciones hash, firmas y protección de contraseñas

4.1. Funciones hash

Una función hash genera un resumen de los datos de entrada.

Fichero | ▼ Función HASH | ▼ Resumen

El resultado tiene una longitud determinada por el algoritmo.

Algunos algoritmos conocidos:

SHA-256. SHA-384. SHA-512.

4.2. Características de los hashes

Una función hash criptográfica debe dificultar:

Obtener los datos originales a partir del hash. Encontrar dos entradas con el mismo hash. Manipular los datos sin que el cambio sea detectable.

Una característica importante es el efecto avalancha.

Por ejemplo:

"Hola"

SHA-256 ↓ Hash A

"hola"

SHA-256 ↓ Hash B

Un cambio aparentemente pequeño en los datos produce un resultado completamente diferente.

4.3. Hash y contraseñas

Los hashes se han utilizado tradicionalmente para almacenar contraseñas, pero no es suficiente aplicar directamente SHA-256 a una contraseña.

Para almacenar contraseñas deben utilizarse funciones específicas de derivación de claves, como:

Argon2. bcrypt. scrypt. PBKDF2.

Estas funciones permiten hacer más costoso el proceso de probar muchas contraseñas.

4.4. Salt

El salt es un valor adicional, normalmente aleatorio, que se combina con la contraseña antes de aplicar la función de derivación.

Contraseña + Salt | ▼ Función de derivación | ▼ Resultado almacenado

El uso de un salt diferente para cada contraseña dificulta determinados ataques basados en valores precalculados.

El *salt* debe generarse de forma aleatoria y almacenarse junto al resultado derivado; no es una clave secreta. En sistemas con requisitos elevados puede añadirse un *pepper*, un valor secreto gestionado separadamente por la aplicación. Para contraseñas no se deben diseñar algoritmos propios ni usar cifrado reversible: se usan funciones como Argon2id, bcrypt, scrypt o PBKDF2 con parámetros revisados según el entorno.

4.5. Firma digital

Una firma digital permite comprobar principalmente:

Integridad. Autenticidad.

Proceso simplificado:

Documento | ▼ HASH | ▼ Firma con clave privada | ▼ Firma digital

El receptor utiliza la información pública correspondiente para verificar la firma.

4.6. Cifrado frente a firma digital

No debemos confundir ambos conceptos.

Cifrado	Firma	Protege confidencialidad	Protege integridad/autenticidad	Oculto información	Permite verificar el origen
Utiliza mecanismos de cifrado	Utiliza mecanismos de firma	Busca impedir la lectura	Busca detectar modificaciones y verificar el firmante		

Una información puede estar:

Cifrada. Firmada. Cifrada y firmada. Ni cifrada ni firmada.

5. Certificados, PKI y TLS

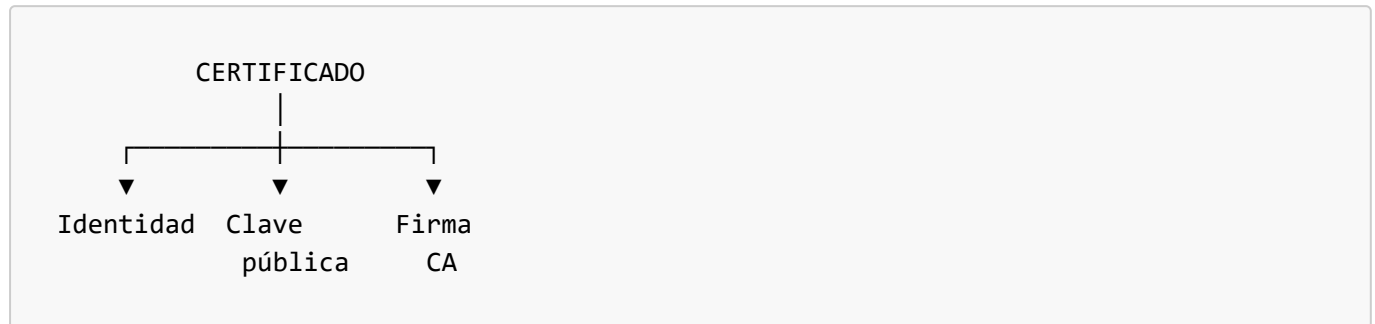
5.1. Certificados digitales

Un certificado digital permite asociar una identidad con una clave pública.

Un certificado puede contener información como:

Identidad del titular. Clave pública. Emisor. Número de serie. Periodo de validez. Algoritmos utilizados. Firma de la autoridad certificadora.

Ejemplo:



5.2. Autoridad de certificación

Una CA (Certificate Authority) es una entidad que emite y firma certificados digitales.

Su función principal es establecer una relación de confianza entre:

Identidad ←—— Certificado ———→ Clave pública

Los sistemas operativos y navegadores incorporan autoridades certificadoras de confianza.

5.3. PKI

Una PKI (Public Key Infrastructure) es una infraestructura destinada a gestionar claves públicas y certificados digitales.

Puede incluir:

Autoridades certificadoras. Autoridades de registro. Autoridades de validación. Certificados. Claves. Políticas de certificación. Mecanismos de revocación. Sistemas de comprobación del estado de certificados.

La autoridad de registro comprueba la identidad del solicitante antes de la emisión. La autoridad de validación informa sobre el estado de un certificado, por ejemplo mediante OCSP. Los repositorios publican certificados y listas de revocación para que los clientes puedan construir y comprobar la cadena de confianza.

5.4. Cadena de confianza

Los certificados pueden formar una cadena de confianza.

Ejemplo:

CA raíz | ▼ CA intermedia | ▼ Certificado servidor | ▼ www.empresa.es

El cliente puede comprobar la cadena hasta llegar a una autoridad que considera de confianza.

5.5. Revocación de certificados

Un certificado puede dejar de ser válido antes de su fecha de caducidad.

Por ejemplo:

Se ha comprometido la clave privada. Se ha producido un error en la emisión. La identidad asociada ha cambiado. Ya no se desea utilizar el certificado.

Existen mecanismos como:

CRL. OCSP.

5.6. TLS y HTTPS

HTTPS utiliza TLS para proteger las comunicaciones entre clientes y servidores.

Simplificando el proceso:

Cliente | | conexión TLS ▼ Servidor | |— Certificado |— Autenticación |— Negociación criptográfica |
▼ Comunicación segura

TLS utiliza diferentes mecanismos criptográficos para conseguir una comunicación segura.

Durante la conexión, el cliente valida que el certificado corresponde al nombre del servicio, que está dentro de su periodo de validez y que encadena con una autoridad de confianza. Un certificado válido no garantiza por sí solo que una web sea legítima o segura: también importa la configuración del servidor, las actualizaciones y la protección de su clave privada.

5.7. Tipos y formatos de certificados

Los certificados pueden clasificarse por su uso: de servidor para HTTPS, personales para identificación o firma, de firma de código y de autoridad de certificación. Según la validación, los certificados de dominio (DV) comprueban el control de un dominio, los de organización (OV) incluyen comprobaciones sobre la entidad y los de validación extendida (EV) aplican un proceso adicional. El nivel de validación no sustituye la revisión del servicio ni convierte una web en segura por sí mismo.

El formato más habitual es X.509. Los certificados y claves se encuentran con frecuencia en PEM, una codificación de texto Base64 delimitada por encabezados como **BEGIN CERTIFICATE**. DER es una codificación binaria de X.509. PKCS#12, también llamado PFX, puede contener certificado y clave privada protegidos con contraseña; por ello requiere una custodia especialmente estricta. PKCS#7 permite distribuir certificados y cadenas sin incluir claves privadas.

5.8. Criptografía cuántica y post-cuántica

La distribución cuántica de claves utiliza propiedades físicas de sistemas cuánticos para detectar la interceptación de una clave. En protocolos como BB84, las partes intercambian estados cuánticos y comparan información por un canal clásico; medir esos estados altera el resultado y permite detectar una posible escucha. No cifra por sí misma todos los datos ni sustituye la criptografía convencional: proporciona un mecanismo especializado de distribución de claves.

Los ordenadores cuánticos a gran escala podrían afectar a RSA, Diffie-Hellman y ECC mediante algoritmos como Shor. En cambio, el cifrado simétrico y las funciones hash no se rompen del mismo modo, aunque conviene utilizar tamaños de clave apropiados. Esta amenaza es relevante para información que necesita

confidencialidad durante muchos años, porque un adversario puede guardar hoy comunicaciones cifradas para intentar descifrarlas en el futuro.

La criptografía post-cuántica busca algoritmos resistentes a ataques clásicos y cuánticos. NIST ha publicado estándares iniciales como ML-KEM para establecimiento de claves, ML-DSA para firmas y SLH-DSA para firmas basadas en hash. La migración debe planificarse con agilidad criptográfica: inventariar dónde se usan algoritmos y certificados, mantener componentes actualizados y poder sustituirlos sin rediseñar todo el servicio. No es necesario crear algoritmos propios ni abandonar TLS actual; el objetivo es prepararse para adoptar soluciones estandarizadas cuando los proveedores las incorporen.

6. Resumen

La criptografía protege información y comunicaciones mediante mecanismos con finalidades distintas: el cifrado aporta confidencialidad, los hashes permiten comprobar integridad, las firmas prueban integridad y autenticidad, y los certificados vinculan una identidad con una clave pública.

Los sistemas actuales combinan criptografía simétrica para proteger datos de forma eficiente y criptografía asimétrica para autenticarse o establecer claves. La seguridad depende también de usar algoritmos normalizados, evitar mecanismos obsoletos y custodiar, rotar y revocar correctamente las claves.

7. Recursos

- [NIST: Cryptographic Standards and Guidelines](#)
- [NIST: criptografía post-cuántica](#)
- [Documentación de OpenSSL](#)
- [Documentación de GnuPG](#)
- [Let's Encrypt](#)

8. Relación con los resultados de aprendizaje

Esta unidad contribuye a la adopción de prácticas seguras, la protección de información, la autenticación de sistemas y usuarios, y la aplicación de mecanismos criptográficos en comunicaciones y servicios.